

Cyber crimes & Security Compliance & frameworks



Cyber crimes & Security Compliance & frameworks

1. Types of Cyber Crimes
2. Cyber Crime reporting
3. Cyber Compliance
4. NIST Standard
5. ISO 27001
6. CIS Benchmark

Labs:

- Configure a windows 10 computer as per the CIS Benchmark

Cyber Crime

- Cyber crime refers to any illegal activity in which computers, digital systems, networks, or data are the primary target, the tool used, or both.
- It spans offenses from unauthorized access and fraud to disruption of services and digital espionage.
- Characteristics of Cyber Crime:
 - Conducted via internet, networks, or digital devices
 - Involves compromise of confidentiality, integrity, or availability (CIA triad)
 - Can target individuals, organizations, or governments
 - Often transnational, making attribution and prosecution complex



Major Categories of Cyber Crime

- **Crimes Against Individuals**

- Identity theft
- Phishing and online scams
- Cyberstalking and harassment
- Financial fraud (UPI, credit card, online banking)

- **Crimes Against Organizations**

- Ransomware attacks
- Data breaches
- Intellectual property theft
- Business Email Compromise (BEC)
- Insider threats

- **Crimes Against Government / Critical Infrastructure**

- Cyber espionage
- Nation-state attacks
- DDoS on public services
- Election interference

- **Device & Network Exploitation**

- Malware distribution
- Botnets
- Cryptojacking
- Unauthorized access / hacking

Types of Cyber Crimes

- **Crimes Against Individuals**

- *Identity Theft* - Stealing personal data (Aadhaar, PAN, passwords)
- *Phishing and Social Engineering* - Fraudulent emails, SMS, calls
- *Online Harassment and Cyber Stalking* - Threats, abuse, blackmail
- *Financial Scams* - Investment scams, Romance scams

- **Crimes Against Organizations**

- *Malware Attacks* - Viruses, worms, Trojans
- *Ransomware* - Encrypts organizational data
- *Insider Threats* - Malicious employees

- **Financial and Economic Cyber Crimes**

- *Online Banking Fraud* - Account takeover
- *Credit/Debit Card Fraud* - Card-not-present (CNP) fraud
- *Cryptocurrency Crimes* - Crypto scams

Types of Cyber Crimes

- **Crimes Against Data and Privacy**

- *Data Breaches* - Unauthorized access to sensitive data
- *Data Theft* - Stealing intellectual property
- *Privacy Violations* - Illegal surveillance

- **Cyber Crimes Against Infrastructure**

- *Denial of Service (DoS/DDoS)* - Flooding services to make them unavailable
- *Critical Infrastructure Attacks* - Power grids

- **Network and System-Based Crimes**

- *Unauthorized Access (Hacking)* - Exploiting vulnerabilities, Password cracking
- *Privilege Escalation* - Gaining higher access than authorized
- *Lateral Movement* - Moving across systems after initial access

Types of Cyber Crimes

- **Web and Application-Based Crimes**

- *Web Attacks* - SQL injection, Cross-site scripting (XSS)
- *Website Defacement* - Altering website content illegally

- **Intellectual Property Crimes**

- *Software Piracy* - Illegal copying/distribution of software
- *Copyright Infringement* - Illegal sharing of digital content

- **Cyber Espionage and Warfare**

- *Cyber Espionage* - State-sponsored spying, Stealing sensitive information
- *Cyber Terrorism* - Disrupting systems to create fear or harm
- *Information Warfare* - Disinformation campaigns, Psychological operations

- **Emerging and Advanced Cyber Crimes**

- *AI-Enabled Crimes* - Deepfake fraud, AI-generated phishing
- *IoT-Based Attacks* - Smart device exploitation
- *Supply Chain Attacks* - Compromising trusted vendors



Cyber Crime reporting

- Cyber crime reporting is the formal process of notifying authorized agencies about digital crimes such as
 - ✓ Online financial fraud (UPI, card, net banking)
 - ✓ Phishing, smishing (SMS Phishing), vishing (voice call frauds)
 - ✓ Account hacking and identity theft
 - ✓ Ransomware and malware attacks
 - ✓ Email fraud and BEC
 - ✓ Cyber stalking, bullying, harassment
 - ✓ Data breaches and privacy violations
 - ✓ Website hacking and defacement



Why Cyber Crime Reporting Is Important?

- Enables law enforcement investigation
- Helps recover stolen money or data
- Prevents further victimization
- Creates legal evidence and audit trails
- Supports national cyber threat intelligence

Note – Delays in reporting often reduce the chances of recovery, especially in financial fraud cases.

Cyber Crime Reporting in India

- National Cyber Crime Reporting Portal
- Portal: <https://cybercrime.gov.in>
- You can report:
 - Financial fraud
 - Social media crimes
 - Online harassment
 - Identity theft
 - Cyber terrorism (restricted category)



Extra - National Cyber Crime Reporting Portal

भारत सरकार
GOVERNMENT OF INDIA

गृह मंत्रालय
MINISTRY OF HOME AFFAIRS

Language 


सत्यमेव जयते


Indian Cyber Crime Coordination Centre
समर्पित करवाइये • Working Together With Vigour

राष्ट्रीय साइबर अपराध रिपोर्टिंग पोर्टल
National Cyber Crime Reporting Portal


75
आज़ादी का
अमृत महोत्सव

 Register a Complaint + Track your Complaint Report & Check Suspect + Cyber Volunteers + Learning Corner + Contact Us


गृह मंत्रालय
MINISTRY OF HOME AFFAIRS
सत्यमेव जयते


75
Azadi Ka
Amrit Mahotsav


Indian Cyber Crime Coordination Centre


WOMEN/CHILDREN RELATED CRIME


FINANCIAL FRAUD


OTHER CYBER CRIME

What's new

https://cybercrime.gov.in/Webform/cyber_suspect.aspx

Important Alert!!!! Fake mails are being sent impersonating officials of Indian Cyber Crime Coordination Centre - CEO I4C, Intelligence Bureau and Delhi Police. The claim is FAKE.



Extra - Evidence to Collect Before Reporting

- Screenshots of emails, messages, websites
- Transaction IDs and bank statements
- Email headers
- URLs and IP addresses (if available)
- Logs (for organizations)
- Ransom notes or malware samples (do not execute)
- Preserve original evidence; do not modify files.



Extra - Cyber Crime Reporting for Organization

Organizations should:

- Follow incident response playbooks
- Notify:
 - CERT-In (Computer Emergency Response Team - India)
 - Law enforcement
 - Regulators (RBI, SEBI, IRDAI, etc.)
- Preserve logs for 180 days or more
- Conduct post-incident forensic analysis



Extra - What Happens After Reporting

- Complaint is assigned to cyber crime cell
- Preliminary verification is conducted
- Bank accounts/domains may be frozen
- Investigation and legal proceedings initiated
- Victim may be contacted for additional details

Extra - International Reporting (Outside India)

- Report to local cyber crime units
- Notify national CERT
- Report phishing to:
 - Email provider
 - Domain registrar
 - Hosting provider



Cyber Compliance

- Cyber Compliance refers to the process of ensuring that an organization's information systems, security controls, policies, and operations conform to applicable laws, regulations, and industry standards related to cybersecurity, data protection, and privacy.
- It is a governance and risk management discipline, not merely a technical exercise.
- Cyber compliance is continuous, multi-dimensional, and business-critical.
- Organizations that treat compliance as a strategic risk management function—not a checkbox—achieve stronger security, resilience, and regulatory trust.

Objectives of Cyber Compliance

- Protect confidentiality, integrity, and availability (CIA) of information
- Reduce legal, regulatory, and financial risk
- Establish accountability and auditability
- Enable trust with customers, partners, and regulators
- Support incident readiness and reporting obligations

Key Cyber Compliance Domains

- **Governance and Risk Management**

- Information Security Policy
- Risk assessment and risk treatment
- Roles and responsibilities (CISO, DPO)
- Third-party risk management

- **Identity and Access Management (IAM)**

- Least privilege and role-based access
- Multi-Factor Authentication (MFA)
- Privileged Access Management (PAM)
- Periodic access reviews

- **Data Protection and Privacy**

- Data classification and labeling
- Encryption at rest and in transit
- Data retention and deletion policies
- Privacy impact assessments (PIA/DPIA)

- **Infrastructure and Network Security**

- Firewalls and network segmentation
- Secure configuration baselines
- Vulnerability management
- Patch management

Key Cyber Compliance Domains

- **Endpoint and Application Security**

- Antivirus / EDR / XDR
- Secure SDLC
- Application security testing
- Mobile and BYOD security

- **Monitoring, Logging, and Incident Response**

- Centralized logging (SIEM)
- Security monitoring and alerting
- Incident response plans and playbooks
- Forensic readiness

Major Cyber Compliance Standards and Regulations

International Standards

- ISO/IEC 27001 – Information Security Management System (ISMS)
- ISO/IEC 27701 – Privacy Information Management
- NIST Cybersecurity Framework (CSF)
- CIS Critical Security Controls

Data Protection and Privacy Laws

- GDPR (EU)
- DPDP Act, 2023 (India)
- HIPAA (Healthcare)
- CCPA / CPRA (California)

Industry-Specific Regulations

- PCI DSS – Payment Card Data
- SOX – Financial reporting
- RBI Cyber Security Framework (India – BFSI)
- SEBI / IRDAI Cyber Guidelines



Cyber Compliance in India

IT Act, 2000 & Amendments

Sections 43, 66, 72A

Reasonable security practices

CERT-In Directions (2022)

Mandatory incident reporting within 6 hours

Log retention for 180 days

Time synchronization (NTP)

KYC for cloud/VPN providers

Digital Personal Data Protection (DPDP) Act

Lawful data processing

Consent management

Breach notification

Data principal rights



Cyber Compliance Lifecycle

1. Identify applicable regulations
2. Perform gap assessment
3. Define policies and controls
4. Implement technical and administrative safeguards
5. Monitor and log continuously
6. Conduct internal and external audits
7. Report incidents and breaches
8. Continuous improvement

Cyber Compliance vs Cyber Security

Aspect	Cyber Security	Cyber Compliance
<i>Focus</i>	Protection	Adherence
<i>Approach</i>	Risk-based	Rule-based
<i>Scope</i>	Technical	Technical + Legal
<i>Outcome</i>	Risk reduction	Regulatory alignment

NIST Standard

- NIST (**National Institute of Standards and Technology**) develops globally adopted cybersecurity standards, frameworks, and guidelines that help organizations manage cyber risk in a systematic, measurable, and repeatable manner.
- NIST standards are widely used across government, critical infrastructure, and private enterprises.
- NIST standards provide a practical, risk-driven approach to cybersecurity that balances security effectiveness, compliance, and operational flexibility.
- They are best used as a living framework, not a static checklist.



Importance of NIST

Vendor-neutral and
technology-agnostic

Risk-based rather
than prescriptive

Mapped to ISO, CIS,
PCI DSS, HIPAA, and
GDPR

Suitable for small
businesses to large
enterprises

Widely accepted by
regulators and
auditors



Core NIST Cybersecurity Publications

1. NIST Cybersecurity Framework (CSF)

- The NIST CSF provides a **high-level structure** for managing cybersecurity risk.
- Five Core Functions
 - **Identify** – Asset management, risk assessment, governance
 - **Protect** – Access control, training, data security
 - **Detect** – Continuous monitoring, anomaly detection
 - **Respond** – Incident response, communications
 - **Recover** – Recovery planning, improvements



Core NIST Cybersecurity Publications

2. NIST SP 800-53 — Security & Privacy Controls

- A **comprehensive catalog** of controls for federal and enterprise systems.

- Control Families (Examples)

- AC – Access Control
- IA – Identification & Authentication
- CM – Configuration Management
- IR – Incident Response
- CP – Contingency Planning
- AU – Audit & Accountability
- SC – System & Communications Protection

Used heavily for:

- Government systems
- Critical infrastructure
- Compliance audits

Other publications

- **NIST SP 800-171 — Controlled Unclassified Information (CUI)**
 - Protects CUI in non-federal systems
 - Mandatory for government contractors
 - 14 control families aligned to 800-53
- **NIST SP 800-61 — Incident Response Guide**
 - Defines:
 - Incident response lifecycle
 - Detection, analysis, containment, eradication, recovery
 - Post-incident lessons learned



Other publications

- **NIST SP 800-92 — Log Management**

- Centralized logging
- Retention policies
- SIEM integration
- Forensic readiness

- **NIST SP 800-30 — Risk Assessment**

- Threat identification
- Vulnerability analysis
- Likelihood and impact assessment
- Risk determination

- **NIST SP 800-63 — Digital Identity Guidelines**

- Identity proofing
- Authentication assurance levels
- MFA and password guidance

NIST and Compliance Alignment

- NIST maps to:
 - ISO/IEC 27001
 - CIS Controls
 - PCI DSS
 - HIPAA
 - GDPR
 - DPDP Act (India)



HIPAA



PCI DSS



GDPR

- This makes NIST ideal as a foundational framework.

ISO 27001

- ISO stands for the **International Organization for Standardization**, the independent body that publishes this key global standard, developed jointly with the International Electrotechnical Commission (IEC), to help organizations manage information security risks through an **Information Security Management System (ISMS)**.
- What ISO 27001 Does:
 - **Framework:** ISO 27001 offers a systematic approach for organizations to establish, implement, maintain, and continuously improve how they manage information security.
 - **Requirements:** It sets out specific requirements for an ISMS, guiding organizations to identify, assess, and treat information security risks in a structured way.
 - **Global Standard:** ISO ensures this standard is internationally recognized, making it a benchmark for data security globally, regardless of an organization's size or sector.



ISO 27001

- **Purpose of ISO 27001:**

- Ensure confidentiality, integrity, and availability (CIA) of information
- Systematically manage information security risks
- Demonstrate compliance to customers, partners, and regulators
- Establish governance, accountability, and continuous improvement

- **Scope of ISO 27001:**

- IT systems, networks, applications
- Cloud and on-prem environments
- Business processes and third parties
- Employees, contractors, and vendors



ISO 27001 Risk Management Process

1. Asset identification
2. Threat and vulnerability assessment
3. Risk evaluation
4. Risk treatment:
 - Mitigate
 - Transfer
 - Avoid
 - Accept
5. Risk acceptance documentation



Benefits of ISO 27001

- Reduced security incidents
- Improved regulatory compliance
- Increased customer trust
- Stronger vendor assurance
- Improved incident readiness

CIS Benchmark

- CIS Benchmarks are consensus-based, vendor-neutral security configuration guidelines developed by the Center for Internet Security (CIS).
- They define secure baseline configurations for operating systems, cloud platforms, network devices, databases, and applications to reduce attack surface and prevent common cyber threats.
- Purpose of CIS Benchmarks
 - Establish secure configuration baselines
 - Reduce misconfiguration-related breaches
 - Support compliance and audit readiness
 - Provide prescriptive, actionable controls
 - Enable measurable security posture



CIS Benchmarks exist for:

- Operating Systems (Windows, Linux, macOS)
- Cloud Platforms (AWS, Azure, GCP)
- Network Devices (Cisco, Palo Alto, Fortinet)
- Databases (Oracle, MySQL, SQL Server)
- Applications (Docker, Kubernetes, Microsoft 365)



CIS Security Levels

- **Level 1 (L1)**

- Basic security hygiene
- Minimal impact on usability
- Suitable for most systems

- **Level 2 (L2)**

- Defense-in-depth
- Higher security, stricter controls
- Suitable for sensitive or critical systems





That's all Folks!